

GroAurum Platform

Phase 3.5 - Launch Readiness Audit

Date: 2026-07-17
Scope: Customer App, Admin ERP, Salesman PWA, Delivery PWA + infrastructure.
Method: evidence-based audit only. No new features. No UI redesign.

Launch Score: 56 / 100

Classification tally across 25 checklist items: PASS 3 | PARTIAL 19 | FAIL 3. Scoring: PASS=100, PARTIAL=55, FAIL=15 (equal weight).

Recommendation

- Development: READY ? monorepo, migrations, seeds, and four apps run locally.
- Internal Testing: READY ? exercise seeded flows (admin/sales/customer/delivery) with known stubs documented.
- Pilot Launch: CONDITIONAL ? only with COD-only payments, email/password auth, manual job invocation, and ops acceptance of placeholders (OTP SMS, PoD media, reports charts, offline PWA).
- Production Launch: NOT READY ? close FAIL items (cron, edge/webhook security, offline) and critical PARTIAL gaps (admin order RPC, live providers, realtime wiring).

Executive Summary

GroAurum has progressed from scaffold to a coherent B2B platform: live Supabase schema/RLS, role-scoped field PWAs, customer self-serve order placement, and Sprint 9 production-service foundations (payments webhook path, notification outbox, audit/logs, job RPCs). The platform is suitable for internal testing and a tightly controlled pilot. It is not yet production-launch ready because unattended jobs are unscheduled, several security edges are open by default, realtime is unused in apps, and key operator/customer polish items remain stubs.

1. Application Surfaces

PARTIAL	Customer App Live auth/session, catalogue, place order + reserve, orders/account reads. Phone OTP needs SMS; promotions/invoice placeholders; online pay UI not wired; account address edit missing.
PARTIAL	Admin ERP Live catalogue/customer/order-list/pricing/inventory/delivery list CRUD paths. No production login screen (dev auto-sign). Reports charts FAIL live. Service-areas route placeholder; many settings/salesman/delivery detail mutations deferred. Order status update blocked by trusted_server_action without admin RPC.
PARTIAL	Salesman PWA Strongest field surface: auth role gate, dashboard, retailers, invite token, assisted order + MOQ, visits, performance. Assisted OTP confirmation is placeholder (no SMS). Offline = manifest only.
PARTIAL	Delivery PWA Auth, routes, start/complete/fail, COD collect + history live. Photo/signature are boolean placeholders; Maps is external URL; offline = manifest only.

2. Auth, Permissions, CRUD

PARTIAL	Authentication @groaurum/auth + Supabase sessions for admin/sales/delivery; customer custom session. Seeded users work. Phone OTP / production login UX incomplete.
PARTIAL	Permissions Audience + RoleGuard + AdminModuleGuard present. Live DB collapses ADMIN to super_admin; fine-grained ERP roles are mock-only. READ_ONLY order visibility gap.
PARTIAL	CRUD Core admin mutations wired (Sprint 5.1). Gaps: reports write, service areas UI, salesman create UI unused, delivery detail actions deferred, admin order status RPC.

3. Domain Capabilities

PARTIAL	Realtime createSupabaseRealtimeBus implemented and attached to domain repos. No app React Query invalidation wiring found ? infrastructure only.
PARTIAL	Notifications notification_outbox + enqueue RPC + send-notification worker. Providers stub without SMS/WA/FCM/email secrets.
PARTIAL	Payments COD live (delivery_collect_cod). Online: intent RPC + Razorpay edges (stub without keys). Webhook apply idempotent; HMAC optional if secret unset.
PARTIAL	Inventory Balances + reserve inside place_* RPCs; expires_at + expire job. Customer InventoryService still proxy; admin adjust path present.
PARTIAL	Orders Customer/salesman place + timeline; delivery OFD/delivered/failed. Admin status transitions lack trusted RPC wrapper.

4. Data & Platform Layer

PARTIAL	RLS Scoped policies for admin/salesman/delivery/customer + Sprint 4?9 extensions. Sensitive writes via SECURITY DEFINER. READ_ONLY incomplete for orders.
PARTIAL	Repository Layer Live api-client services for customer/sales/delivery/payment/notification. AssistedOrder/inventory/deliveryRoute proxies on customer factory; admin reports/dashboard placeholder repos.
PARTIAL	Edge Functions razorpay-create-order, razorpay-webhook, send-notification, expire-reservations, expire-invitations. Shared CORS/log helpers. Job edges lack cron-secret auth.
FAIL	Cron Jobs Job RPCs + HTTP invoke exist. supabase/config.toml has no schedules. Reservation/invitation/notification workers will not run unattended.
PARTIAL	Seeds sprint4 admin/sales/catalogue/shops; sprint6 customer; sprint7 salesman visits; sprint8 delivery route/COD. No READ_ONLY seed; only db:seed:sprint4 scripted.
PASS	Migrations MIGRATION_INDEX 0001?0028 present through Sprint 9 production services. Schema + RLS + RPCs coherent for local reset.
PASS	Environment Variables Per-app .env.example uses public anon keys only. api-client rejects service_role in browser config. Edge secrets documented in functions/README.

5. Quality, Security, UX Hardening

PARTIAL	Performance Solid indexes for core tables. Gaps: payments.provider_reference index; N+1 patterns in LiveAdminApi / listOrdersForShop.
FAIL	Security CORS *: Razorpay webhook verify optional; expire/send edges unauthenticated; enqueue_notification granted to authenticated (outbox flood risk). Service role correctly kept out of apps.
PARTIAL	Accessibility Shared FormControls use labels; bottom nav aria-labels. Customer OTP fields lean on placeholders; focus rings not systematized.
PARTIAL	Error Handling RPC RAISE + edge try/catch + app EmptyState/Alert/QueryStateGate. No structured error codes or global retry/toast layer.
FAIL	Offline Behaviour Sales/Delivery PWA: manifest.json only ? no service worker/cache. Admin mock mode is offline fixtures, not true offline.
PASS	Responsive Layout Field PWAs: 480px mobile shells with safe-area. Admin: responsive sidebar. Customer: Expo SafeArea + tabs. Adequate for intended form factors.

6. Launch Blockers (must close for Production)

- FAIL Cron Jobs: schedule expire-reservations, expire-invitations, send-notification.
- FAIL Security: require Razorpay webhook HMAC; protect job edges with cron secret/JWT; tighten CORS for production.
- FAIL Offline: add service worker / cache strategy for Sales & Delivery PWAs (or explicitly defer offline as non-goal).
- CRITICAL PARTIAL: Admin order status updates need SECURITY DEFINER RPC (trusted_server_action).
- CRITICAL PARTIAL: Wire live SMS/WhatsApp for OTP + invitations; configure Razorpay keys.
- CRITICAL PARTIAL: Subscribe apps to RealtimeBus for order/inventory/delivery KPIs.

7. Acceptable Pilot Constraints

- Auth: email/password seeded users only (defer phone OTP).
- Payments: COD only; online checkout disabled in UI.
- Notifications: outbox stub mode acceptable if ops monitor manually.
- Jobs: ops run expire/send functions on a manual schedule.
- Reports: use operational lists; ignore analytics charts.
- Delivery PoD: notes + failure reasons only (no photo/signature files).

8. Score Breakdown

Launch Score 56/100 reflects a platform that is functionally rich for Gurugram dry-fruit wholesale ops demos and internal QA, but still carries operational and security debt inappropriate for unattended production.

- PASS items (3): Migrations, Environment Variables, Responsive Layout.
- PARTIAL items (19): majority of product + infra ? ship with documented debt.
- FAIL items (3): Cron Jobs, Security defaults, Offline Behaviour.

Final call: READY for Development + Internal Testing. CONDITIONAL Pilot. NOT READY for Production Launch. Score 56/100.